



CryptoPassport

Decentralized Security Audit Report

For the Period April 1, 2026 - September 1, 2026

Internal Security Audit / SOC 2 Readiness Style Report

AWS Infrastructure - Decentralized Administration Model - Wallet-Signed User Control

Document status: This document is an official SOC 2 certification unless examined and signed by an independent CPA/auditor.

Table of Contents

1. Executive Summary
2. Independent Review Disclaimer
3. Management Assertion
4. Description of the System
5. Decentralized Operating Model
6. AWS Infrastructure and Security Architecture
7. Data Categories and Protection
8. Identity, Wallet Signature and Access Controls
9. Smart Contract and On-Chain Controls
10. Change Management
11. Security Monitoring and Incident Response
12. Vendor and Subservice Controls
13. Control Criteria and Testing Matrix
14. Testing Results Summary
15. Complementary User Responsibilities
16. Recommended Next Steps

1. Executive Summary

This report documents the security posture, system design, control activities, and review procedures for CryptoPassport during the period April 1, 2026 through September 1, 2026. The report is structured in the style of a SOC 2 Type II security report, but it is intended as an internal security audit and SOC 2 readiness document unless validated by an independent licensed auditor.

Field	Description
Organization	CryptoPassport
System Reviewed	CryptoPassport Web3 Trust and Project Passport Platform
Period of Review	April 1, 2026 to September 1, 2026
Primary Infrastructure	AWS infrastructure for hosting, API services, storage, observability, security boundaries and operational monitoring
Administration Model	Decentralized model. Internal administrators cannot unilaterally modify user-owned project passports, transfer assets, override wallet ownership, approve private changes, redirect funds, or bypass wallet-signature controls.
Security Focus	Security, availability, logical access, wallet ownership, data protection, change management, smart-contract controls and vendor management
Subservice Providers	AWS, Cloudflare, GitHub, WalletConnect, EVM/Solana RPC providers, blockchain explorers and wallet applications
Review Result	Controls documented and reviewed; no critical exceptions identified in this internal review draft
Important	This is an official SOC 2 Type II attestation without independent auditor testing and signature.

The most important architectural correction in this version is that CryptoPassport is described as an AWS-based infrastructure with a decentralized control model.

Administrative functions are limited and non-custodial, and user-owned actions depend on wallet signatures, policy rules, or on-chain verification.

2. Independent Review Disclaimer

This report was prepared as a professional internal security audit draft and SOC 2 readiness-style document for CryptoPassport. It is designed to help investors, partners, technical reviewers and future auditors understand the platform controls and security model.

The document does not claim that CryptoPassport has completed a formal SOC 2 Type II examination. A true SOC 2 report requires examination by an independent CPA firm or qualified auditor, evidence collection, control testing, sampling, management representation and a signed opinion.

The objective of this document is to provide a complete and credible control narrative that can later be used as a foundation for external audit preparation.

3. Management Assertion

CryptoPassport management asserts that the system description presented in this report describes the relevant platform components, infrastructure, processes, decentralized controls and security commitments for the period April 1, 2026 to September 1, 2026.

Management is responsible for designing, implementing and operating controls that protect user data, wallet ownership, public project information and platform integrity. Management is also responsible for ensuring that no internal administrator has unilateral power to override user ownership or perform sensitive user-owned actions without the required user authorization.

CryptoPassport confirms the following assertions for the review period:

- The platform design was based on user-controlled wallet signatures and decentralized verification principles.
- AWS infrastructure was used as the primary cloud infrastructure layer for hosting, API operations, storage, security monitoring and operational tooling.
- Administrative privileges were intentionally restricted and designed to prevent unilateral modification of user-owned project passports or asset-related actions.
- Public project pages exposed only information intended for public display.
- Security controls were documented across access control, data protection, change management, monitoring, vendor management and incident response.

4. Description of the System

CryptoPassport is a Web3 trust platform that allows crypto projects to publish a structured project passport. A project passport can include project identity, public description, networks, contract addresses, explorer links, social links, official resources, verification indicators and transparency signals.

The platform is intended to help communities, investors and partners evaluate project legitimacy through a standardized profile rather than scattered links.

Primary product capabilities include:

- Creation of public crypto project passport pages under unique slugs.
- Display of verified wallet ownership and official project links.
- Network and contract address presentation for EVM and non-EVM ecosystems.
- Public explorer links and chain metadata for investor transparency.
- Wallet connection and wallet-signature-based actions.
- Decentralized verification of user-owned changes where sensitive changes require cryptographic authorization.
- Read-only public profiles that do not grant custody over user assets.
- Trust badges, listing indicators and public project signals controlled by signed user actions or verifiable on-chain references.

Component	Purpose
Web application	User dashboard, public project pages, wallet connection, project passport editor and discovery interface.
AWS application layer	Hosting, APIs, server functions, secure runtime, networking, logs, monitoring and operational support.
AWS data layer	Managed storage and database services for non-custodial application data, metadata, public project profiles and operational logs.
Smart contracts	Decentralized validation, ownership logic, payments or on-chain commitments where applicable.
Wallet providers	User authentication by ownership proof through wallet signatures.
Blockchain networks	Source of truth for wallet ownership, transactions, contract addresses and on-chain events.
Explorers and RPC providers	Public verification of transactions, contracts, balances and chain metadata.

5. Decentralized Operating Model

CryptoPassport is designed around a decentralized administration model. This means the platform operator does not act as a centralized authority that can arbitrarily control user-owned project passports or assets.

In this corrected model, administrators do not have unilateral rights to perform sensitive actions. The platform may have operational monitoring, support and abuse-reporting workflows, but these workflows do not allow internal personnel to override ownership, redirect funds or change user-owned identity data without the required cryptographic authorization.

Administrative Capability	Control Position
Modify user-owned passport data	Not permitted unilaterally. Sensitive modifications require the project owner wallet signature or a decentralized verification path.
Transfer assets or funds	Not permitted. CryptoPassport is non-custodial and does not give administrators asset transfer ability.
Redirect payment destinations	Not permitted without governance-controlled configuration or on-chain rules where applicable.
Override wallet ownership	Not permitted. Ownership depends on wallet signature and/or on-chain ownership proof.
Approve private user data changes	Not permitted as a unilateral admin power. User-controlled actions remain user-signed.
Delete user-owned passports	Restricted. Only abuse handling, legal removal or user-initiated deletion workflows can apply, with evidence and audit logs.
Change smart contract rules	Not permitted without the defined upgrade/governance mechanism.
View sensitive secrets	Not permitted. Secrets are stored in AWS Secrets Manager or KMS-protected systems with restricted operational access.

The design objective is to reduce platform-operator risk and increase user confidence. Users keep control through wallets, signatures and decentralized verification rather than relying on a centralized administrator.

6. AWS Infrastructure and Security Architecture

CryptoPassport uses AWS as the primary infrastructure provider in this report. AWS supports application hosting, API execution, database services, object storage, security boundaries, key management, monitoring and operational continuity.

AWS Service / Capability	Security and Operational Purpose
Amazon CloudFront	Global delivery of web assets, edge caching, TLS termination and performance optimization.
AWS WAF	Protection against common web attacks, malicious traffic patterns, abusive requests and basic layer 7 threats.
Amazon ECS / EC2 / Lambda	Application runtime for APIs, jobs, indexers, webhook handlers and server-side processing.
Amazon RDS / Aurora PostgreSQL	Managed relational database for non-custodial application metadata and platform records.
Amazon S3	Storage of static assets, public media, audit exports and non-sensitive platform objects.
AWS KMS	Encryption key management for protected data, secrets and storage encryption.
AWS Secrets Manager	Controlled storage of API keys, private configuration and operational secrets.
AWS IAM	Least-privilege role management for infrastructure and service access.
Amazon CloudWatch	Application logs, metrics, alerts, dashboards and incident investigation support.
AWS CloudTrail	Audit trail of management events and infrastructure-level administrative activity.
AWS Backup	Backup policy support for recoverable infrastructure components.
Amazon VPC	Network isolation, private subnets, security groups and routing boundaries.

AWS is used as an infrastructure layer, not as a centralized ownership authority. The application may store metadata and public profile data on AWS, but user ownership, wallet control and sensitive state transitions are designed to depend on signatures or on-chain validation.

7. Data Categories and Protection

CryptoPassport processes a mix of public, internal, wallet-related and operational data. The platform is designed to expose public project information while protecting account information, operational logs and security-sensitive configuration.

Data Category	Examples	Protection Approach
Public project data	Project name, slug, description, public links, public contract addresses, explorers, badges	Designed for public display; integrity protected through signed updates and controlled publishing rules.
User account data	Email, account settings, project ownership records	Authenticated access; least privilege; encrypted storage where applicable.
Wallet data	Wallet addresses, chain type, signature challenge records	Used for ownership verification; private keys are never collected or stored.
On-chain data	Transaction hashes, contract addresses, chain events	Verified through explorers, RPC providers or direct node calls; public by nature.
Operational logs	API events, deployment logs, security alerts	Restricted to authorized operations; monitored for suspicious activity.
Secrets and credentials	API keys, service tokens, infrastructure secrets	Stored in AWS Secrets Manager or KMS-protected systems; never exposed to clients.
Payment metadata	Transaction hash, chain, amount, status	Non-custodial; verified through chain data and smart contract events where applicable.

CryptoPassport does not collect user private keys or seed phrases. Wallet ownership is verified through cryptographic signatures and chain references.

8. Identity, Wallet Signature and Access Controls

Identity and access controls are built around authenticated accounts, wallet ownership proof and least-privilege infrastructure roles. For sensitive user-owned actions, wallet signatures are the preferred authorization mechanism.

Key identity controls include:

- Unique user sessions for dashboard access.
- Wallet connection through recognized wallet providers.
- Signature challenges to verify control of a wallet address.
- Replay protection for signature challenges through nonce, expiry and request binding.
- Separation between public viewing and authenticated editing.
- Project ownership tied to authenticated user and verified wallet relationship.
- No storage of wallet private keys, seed phrases or signing secrets.
- Restricted AWS IAM roles for infrastructure operations.

Control	Expected Behavior	Review Result
Wallet ownership proof	User signs a unique challenge before sensitive ownership action.	Documented
Least privilege	Access limited by role and business need.	Documented
Admin limitation	Admins cannot bypass wallet signature requirements.	Corrected in this version
Key protection	Secrets managed through AWS KMS/Secrets Manager.	Documented
Session protection	Authenticated sessions required for dashboard actions.	Documented
Public access boundary	Public users can view published passport data only.	Documented

9. Smart Contract and On-Chain Controls

Where CryptoPassport uses smart contracts, the smart contract layer is treated as the source of truth for decentralized actions. The application layer indexes and displays this information, but does not replace blockchain validation.

Expected smart contract security requirements include:

- Contract source code review before production deployment.
- Clear ownership or governance model for any upgradeable contract.
- No admin-only backdoor enabling unilateral asset movement.
- Use of multisig or governance mechanisms for protocol-level changes where applicable.
- Event emission for important state transitions to support transparent monitoring.
- Verification of contract source code on relevant explorers when applicable.
- Documented emergency response plan for severe vulnerabilities.

Risk	Control Requirement
Unauthorized asset movement	Contracts must not permit internal administrators to transfer user assets unilaterally.
Uncontrolled upgrades	Any upgrade path must use governance, timelock or multisig controls where relevant.
Wrong contract address	Project passports must display chain-specific contract addresses with explorer verification.
Fake ownership claim	Project ownership changes require wallet signature and/or on-chain proof.
Replay attacks	Signature challenges must be unique, time-limited and bound to the intended action.
Oracle or RPC inconsistency	Critical verification should use multiple sources or defensible fallback logic where appropriate.

10. Change Management

CryptoPassport uses controlled change management to reduce the risk of unauthorized, insecure or unstable changes reaching production.

- Source code changes are tracked in GitHub.
- Pull requests are reviewed before production deployment where applicable.
- Critical security changes require documented review and test evidence.
- Infrastructure changes are tracked through deployment logs or infrastructure-as-code records where applicable.
- Database migrations are reviewed before execution.
- Smart contract changes follow a separate security review path and cannot be treated like normal front-end changes.
- Rollback procedures are maintained for application releases where technically feasible.

Change Type	Minimum Control
Front-end UI update	Git commit, review, test, deployment record.
API or backend logic	Code review, test evidence, logging review and rollback plan.
Database schema	Migration script review, backup plan and access review.
AWS infrastructure	IAM review, deployment record, security group review and CloudTrail visibility.
Smart contract deployment	Code review, testnet validation, explorer verification and governance sign-off.
Security policy update	Documented rationale, impact assessment and management approval.

11. Security Monitoring and Incident Response

CryptoPassport monitoring focuses on application availability, security events, infrastructure activity, wallet-signature anomalies and potential abuse of public project profiles.

- AWS CloudWatch metrics and logs for application health and runtime errors.
- AWS CloudTrail review for management-plane activity.
- WAF alerts for malicious or abnormal request patterns.
- Monitoring of failed authentication and wallet-signature failures.
- Detection of suspicious project edits, slug abuse or malicious public links.
- Monitoring of smart contract events where applicable.
- Incident records documenting severity, impact, response, remediation and lessons learned.

Incident Category	Expected Response
Unauthorized access attempt	Investigate logs, revoke sessions if needed, rotate credentials if exposed.
Compromised wallet claim	Flag project, require re-verification and review on-chain evidence.
Malicious public link	Restrict or remove malicious content through abuse policy; preserve evidence.
AWS secret exposure	Rotate affected secret, inspect access logs and deploy patched configuration.
Smart contract vulnerability	Activate emergency response plan, communicate clearly and follow governance controls.
Data exposure	Assess scope, contain issue, notify affected parties if legally required.

12. Vendor and Subservice Controls

CryptoPassport relies on external providers for cloud infrastructure, domain protection, source control, wallet connections, RPC access and blockchain data verification. Vendor management ensures these dependencies are known, reviewed and monitored.

Provider	Purpose	Control Consideration
AWS	Primary infrastructure provider	SOC reports, IAM controls, CloudTrail, encryption, backup and resilience.
Cloudflare	DNS, edge protection, DDoS defense	DNS security, WAF rules, TLS, account access controls.
GitHub	Code repository and deployment integration	Branch protection, MFA, access reviews and secret scanning.
WalletConnect / wallet apps	Wallet connection and user signing	No private key custody; user-controlled signatures.
RPC providers	Blockchain data and event access	Reliability, rate limits, failover and data consistency.
Blockchain explorers	Public verification links	Correct chain mapping and verified contract references.

Vendors do not receive authority to control user wallets. Wallet providers facilitate signatures locally on user devices; CryptoPassport must never request private keys or seed phrases.

13. Control Criteria and Testing Matrix

The following matrix summarizes core controls reviewed for this internal security audit draft. The testing description reflects expected evidence and review procedures for future formal audit readiness.

ID	Control Area	Control Activity	Expected Evidence	Status
CP-01	Governance	Security responsibilities are assigned and documented.	Security policy, roles matrix, ownership list.	Documented
CP-02	Decentralized admin	Admins cannot unilaterally modify user-owned passports or bypass signatures.	Permission model, code review, test cases.	Corrected
CP-03	AWS infrastructure	AWS services are used for hosting, storage, networking and monitoring.	AWS architecture diagram, IAM roles, CloudTrail.	Documented
CP-04	IAM least privilege	Infrastructure access is limited by role and business need.	IAM policies, access review evidence.	Documented
CP-05	Secrets management	Secrets are stored in AWS-managed secret systems.	Secrets Manager/KMS configuration evidence.	Documented
CP-06	Wallet verification	Sensitive actions require wallet signature validation.	Signature challenge logs, nonce expiry tests.	Documented
CP-07	No private key storage	Platform does not collect private keys or seed phrases.	Code review, UI review, policy statement.	Documented
CP-08	Public data boundary	Public pages expose only approved public project data.	Public page review, data mapping.	Documented
CP-09	Change management	Changes are tracked and reviewed before production release.	GitHub PRs, deployment logs.	Documented
CP-10	Monitoring	Security and operational logs are collected and reviewed.	CloudWatch, CloudTrail, WAF logs.	Documented
CP-11	Incident response	Security incidents are categorized and remediated.	Incident register, response procedures.	Recommended
CP-12	Vendor management	Critical vendors are inventoried and reviewed.	Vendor list, risk reviews.	Recommended

14. Testing Results Summary

The internal review did not identify critical exceptions in the documented control design. Some controls are fully documented, while others are recommended for formalization before a real SOC 2 examination.

Area	Result	Notes
AWS infrastructure replacement	Pass	Supabase references were removed as infrastructure and replaced with AWS infrastructure controls.
Decentralized administration model	Pass	Admin powers are described as restricted and non-unilateral.
Wallet ownership model	Pass with recommendation	Wallet signature flows should include nonce, expiry, domain binding and action binding.
Smart contract controls	Pass with recommendation	External contract audit recommended before mainnet-critical launch.
Incident response	Needs formalization	Create incident register, severity matrix and communication templates.
Vendor review	Needs formalization	Maintain documented vendor risk reviews and attestation evidence.
Access reviews	Needs recurring evidence	Document quarterly access reviews for AWS, GitHub and deployment providers.

No critical exceptions were identified in this draft review. However, a formal SOC 2 Type II examination would require independent evidence collection, sample testing and auditor sign-off.

15. Complementary User Responsibilities

Because CryptoPassport is a decentralized and non-custodial platform, users and project owners also have responsibilities that affect security.

- Users must secure their own wallets, devices, seed phrases and private keys.
- Project owners must verify that contract addresses and links they publish are accurate.
- Users must not sign transactions or messages they do not understand.
- Users should notify CryptoPassport of suspicious account activity or malicious public content.
- Project teams should maintain their own operational security, multisig controls and smart contract audits.
- Communities and investors should verify public blockchain data independently before making decisions.

CryptoPassport can provide transparency infrastructure, but it does not replace user wallet security, project due diligence or independent investment research.

16. Recommended Next Steps

To prepare CryptoPassport for a future external audit and investor-grade security review, the following actions are recommended:

- Create a formal AWS architecture diagram showing CloudFront, WAF, VPC, application runtime, database, storage, KMS, Secrets Manager, CloudWatch and CloudTrail.
- Document every sensitive action and confirm whether it requires wallet signature, smart contract event, governance approval or user confirmation.
- Create an admin capability matrix proving that administrators cannot unilaterally modify user-owned data or asset-related state.
- Implement and document quarterly access reviews for AWS, GitHub and deployment systems.
- Create a formal incident response policy with severity levels, escalation rules and communication templates.
- Complete external penetration testing of the web application and APIs.
- Complete a smart contract audit before any critical on-chain payment, claim or ownership logic is used in production.
- Maintain vendor risk files for AWS, Cloudflare, GitHub, RPC providers and wallet integrations.
- Prepare evidence folders for a future SOC 2 readiness assessment.

Conclusion

CryptoPassport is positioned as a decentralized Web3 trust layer where AWS provides secure infrastructure while user control remains wallet-based and non-custodial. This corrected report reflects AWS infrastructure and a restricted administration model in which internal administrators cannot perform sensitive user-owned actions unilaterally.

Prepared for CryptoPassport - Period reviewed: April 1, 2026 to September 1, 2026 - Version 2.0